



Project 1: **23** days left

Offense-Based Cybersecurity: Exploitation of Human Vulnerabilities

CS 459/559: Science of Cyber Security
9th Lecture

Instructor:

Guanhua Yan

Project 1

- Demonstrate a cyber attack
- In your first project report, please:
 - Explain what are the vulnerability, exploit, attack surface, and attack vector in your project
 - Explain how the attack (exploitation) occurs in your project
 - Explain why the attack (exploitation) works
- Each of your project reports should be **at least five pages, excluding bibliography**
- **Due time: October 8, 2026**
 - **Four days of grace period, with 2.5% penalty each half day late**
- **Grading criteria:**
 - **Results, novelty, difficulty, presentation**

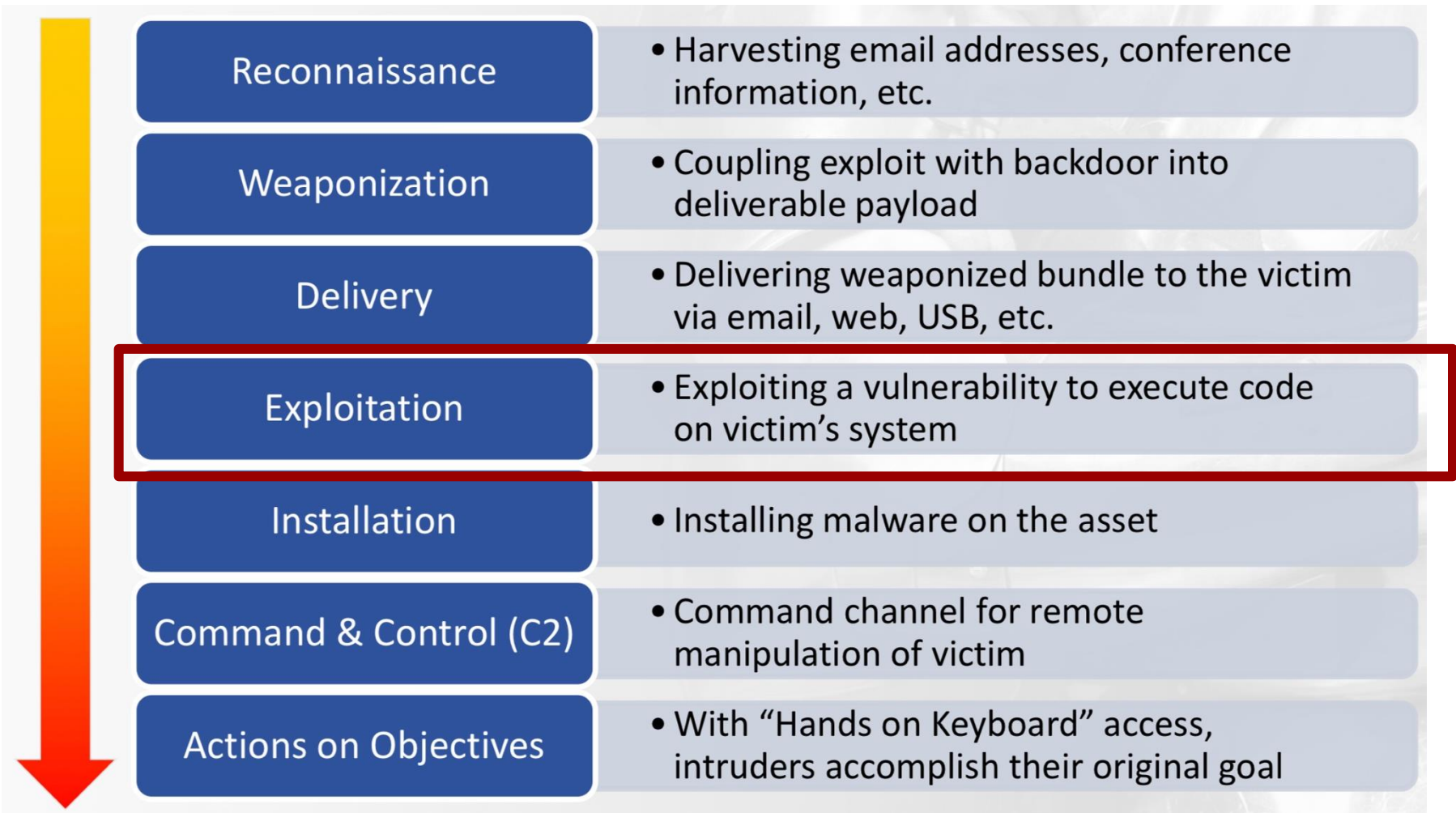
How to choose your project?

- You should be familiar with the concepts behind the attack (software, network, system, or human)
- You should be comfortable with developing defensive mechanisms on the target being attacked
- It's OK to work on known vulnerabilities using known exploit code (plenty of online resources)
 - Known vulnerabilities: National Vulnerability Database (<https://nvd.nist.gov>)
 - Known exploits: Exploit database (<https://exploit-db.com>)
 - The metasploit framework (<https://www.metasploit.com>) makes exploitation easy!
- Start early and work on your project hard!
 - **You will continue working on the same project with defensive techniques introduced in this course**

Agenda

- **Sept 17: human-level attack**
- **Sept 22: Quiz 1 (1:45-2:30PM)**
- **October 8: Project 1 attack report due**
- **October 12-16: Attack demo**

Exploitation of memory vulnerabilities



Introduction

- What is Social Engineering Attack?
- Social Engineering Tactics
 - Quid Pro Quo
 - Phishing/Spear phishing/Smishing/Vishing/etc.
 - Baiting
 - Pretexting
 - Diversion Theft
- Role of AI in Social Engineering Attacks

What is Social Engineering Attack?

- Attacker uses **human interaction** to obtain or compromise information
 - Manipulate people into doing something, rather than by breaking in using technical means
- Attacker may appear **unassuming or respectable**
 - **Pretend** to be a new employee, repair man, etc.
 - May even **offer credentials**
- By asking questions, the attacker may **piece enough information together** to infiltrate a company's network
 - May attempt to get information from many sources

Kevin Mitnick

Famous Social Engineer Hacker

- Went to prison for hacking
- Became ethical hacker

“The biggest threat to the security of a company is not a computer virus, an unpatched hole in a key program or a badly installed firewall. In fact, the biggest threat could be you.” - Kevin

Mitnick



Examples of Social Engineering

- **Kevin Mitnick talks his way into central Telco office**
 - Tells guard he will get a new badge
 - Pretend to work there, give manager name from another branch
 - Fakes a phone conversation when caught
- **Free food at McDonalds**



Example: Greek-Trojan war



- There was a ten-year long campaign between the two nations, Greek and Trojan
- The Greeks **appeared to have been defeated** and, as a parting gift, **built a large wooden horse and left it at the gate of Troy and then appeared to have retreated**
- The Trojans, thinking that they were the victors, **brought the horse into the city and began their victory celebration**
- A few **Greek soldiers, who were hidden inside the horse**, slipped out of their hiding place and **opened the gates for the Greek army**
- **The Greeks won the battle against the Trojans**

Example: RSA attack

- RSA had a **two-factor authentication product** called SecurID
- The attackers sent two different phishing emails over a two-day period. **The recipients were not high profile or high value targets**, and the subject line of the email is “**2011 Recruitment Plan**”.
- The email was well crafted and **one of the employees opened the attached Excel file, which was a spreadsheet containing an Adobe Flash exploit**
- Once inside the network, the attacker performed **privilege escalation attacks** to gain access to higher value administration accounts
- Eventually, the attackers managed to **extract sensitive data**, including the serial numbers of the SecurID token products

Social Engineering Tactics

- **Quid Pro Quo**
 - Something for something
- **Phishing**
 - Fraudulently obtaining private information
- **Baiting**
 - Real world Trojan horse
- **Pretexting**
 - Invented Scenario
- **Diversion Theft**
 - A con

(1) Quid Pro Quo

- **Something for Something**

How a Quid Pro Quo Attack Works

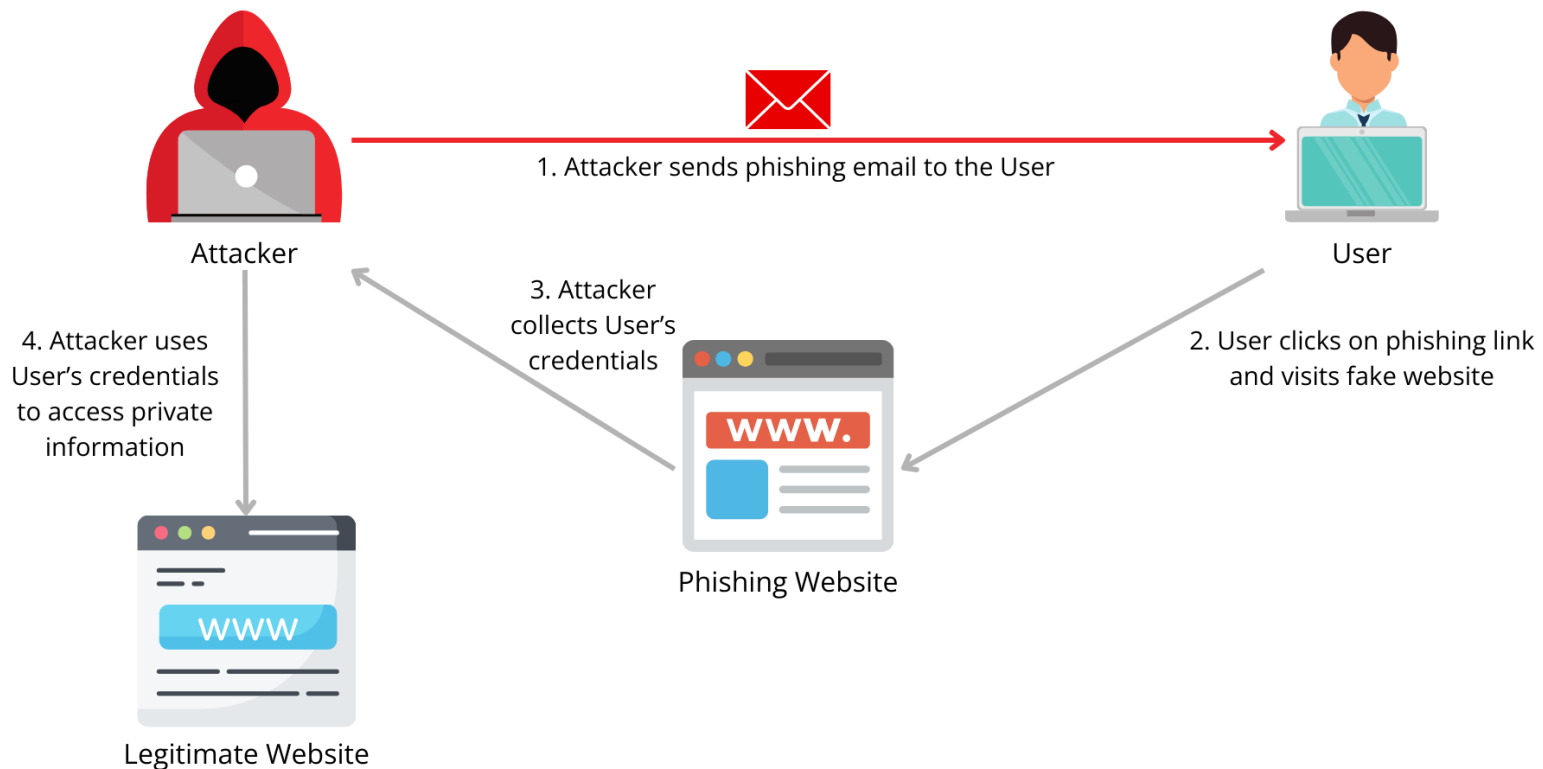


(2) Phishing



- **Fraudulently obtaining private information**

Phishing attack



Phishing attack example

Your PayPal Access Blocked !



PayPal <paypalaccounts@mailbox.com> [Unsubscribe](#) Feb 17, 2019, 4:50 PM   

to me ▼

Your PayPal Account is Limited, Solve in 24 Hours!

Dear PayPal Customer,

We're sorry to say you cannot access all the paypal account features like payment and money transfer.
[Click here to fix your account now.](#)

Why is it blocked?
Because we think your account is in danger of theft and unauthorized uses.

How can I fix the problem?
Confirm all your details on our server. Just click below and follow all of the steps.
[Confirm Account Details Now](#)

Characteristics of phishing attacks

- They seek to obtain **personally identifiable information** (PII), such as names, addresses and social security numbers
- They tend to use **shortened URLs or embed links** that redirect users to sites that appear legitimate
- They usually attempt to **instill a sense of urgency** in the user by using some sort of fear tactic or a threat in an attempt to get the user to act immediately

Spear phishing

Spear Phishing in Action



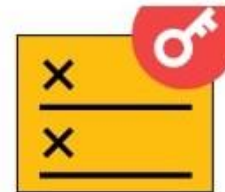
Threat actor
identifies a
target



Sends
legitimate-
looking email



Victim opens the
email containing
malware

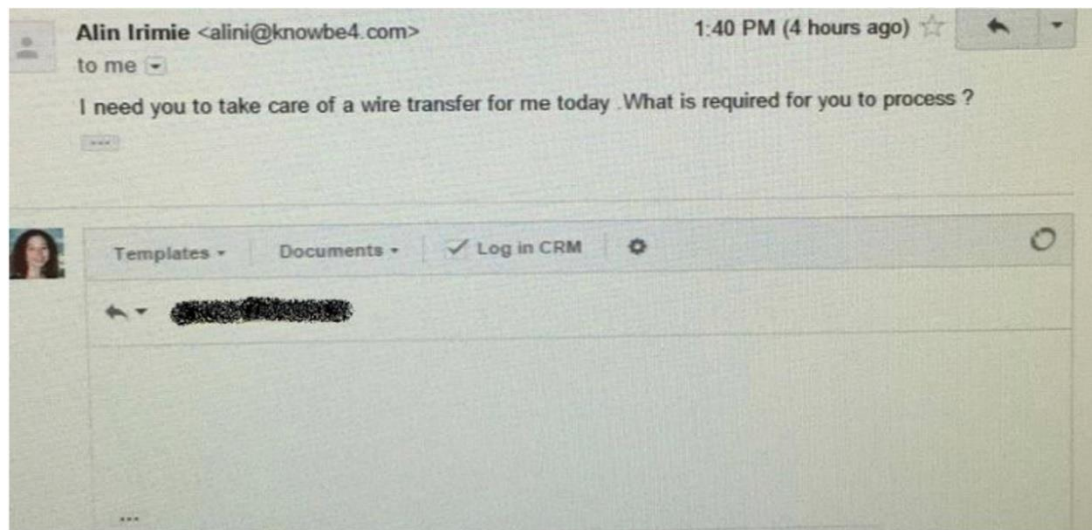


Hacker gains
access to steal
data

- Whereas phishing attacks tend to be very scattered by nature (e.g., a phishing email can be sent to thousands of domains), **spear phishing is much more targeted.**
- Usually a spear phishing attack will **focus on a single organization, a group of individuals within an organization, or even a single individual**

Example of spear phishing attack

- KnowBe4, a Security Awareness Training and Simulated Phishing platform company in the Tampa, FL area, received a spear phishing email in September 2015
- It was received by KnowBe4's Controller allegedly from the "CTO" requesting a wire transfer.
- The Controller went to the CEO. The CEO decided to engage the attacker and to appear to comply with the request.

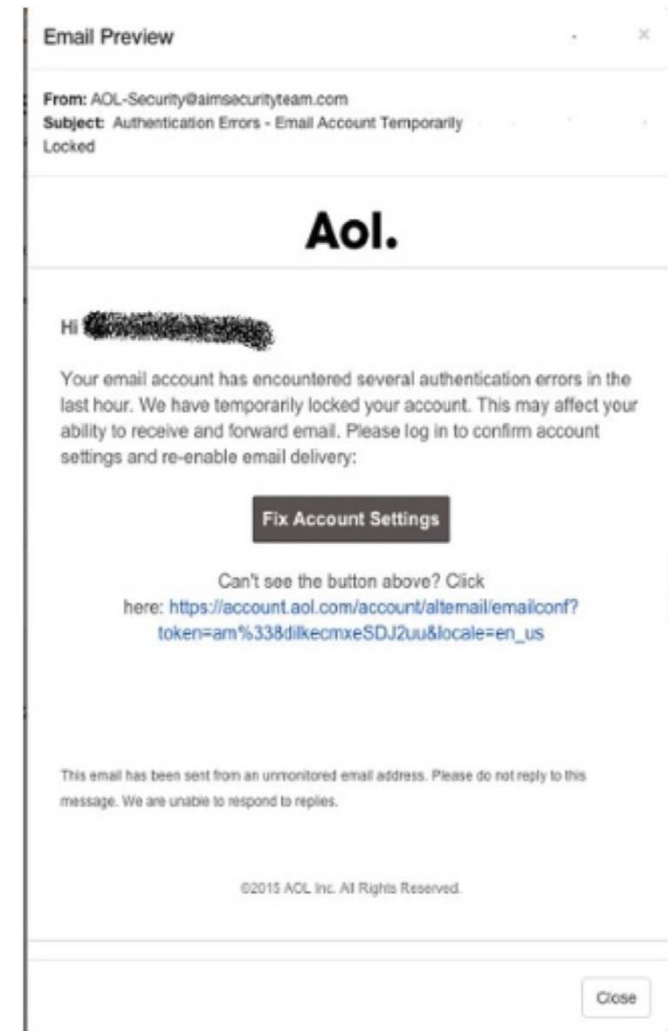


Example of spear phishing attack (cont'd)

- KnowBe4 analyzed the attacker's email.
 - The email headers revealed that the attacker created a hosting account with GoDaddy to get access to an email delivery system.
 - The attacker then used an open source mail client to spoof email headers and pick up the replied-to emails on an AOL account.
- The CEO had the Controller reply back and to the attacker and simply ask "How much and where to?"
- The attacker's reply back contained the bank wire information with real bank info but a fake company name and address.

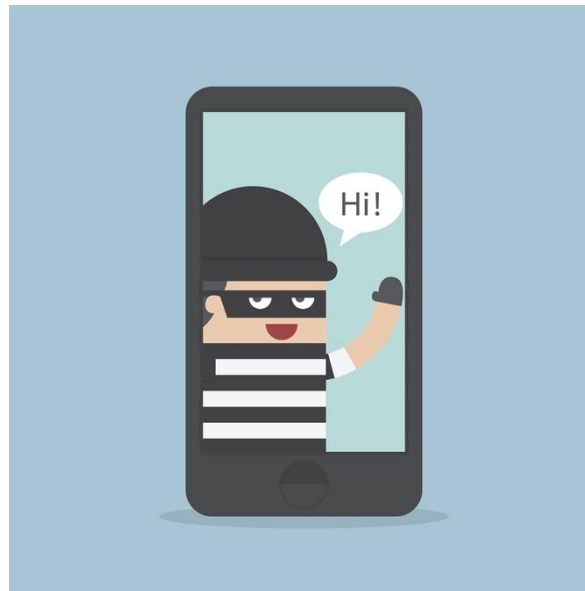
Example of spear phishing attack (cont'd)

- KnowBe4 decided to **phish back the attacker** and **created a fake AOL email account** which **claimed the attacker's account was locked**.
- The attacker then made a fatal error and **clicked on the link** which allowed KnowBe4 to get his IP address.
- This data was then sent over to the AOL security team and the FBI's Internet Crime Complaint Center.

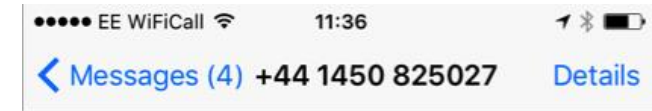


Smishing

- Cell phone attacks typically using text messages to trick users into giving away personal information, or downloading a virus or malware

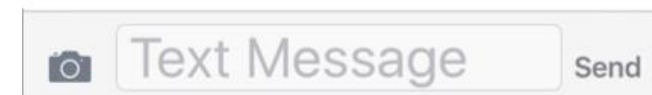


Smishing - Examples

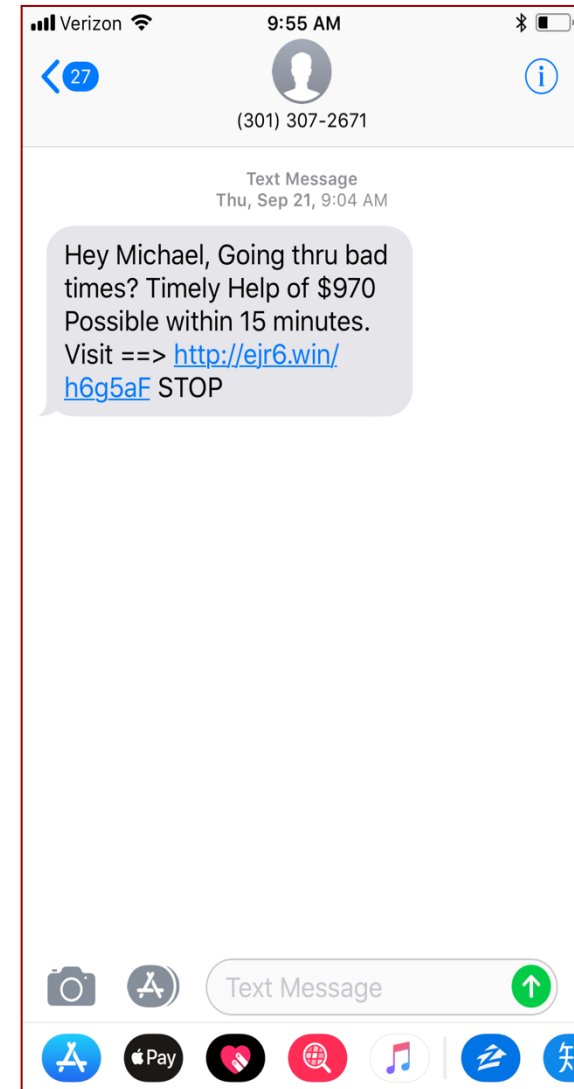
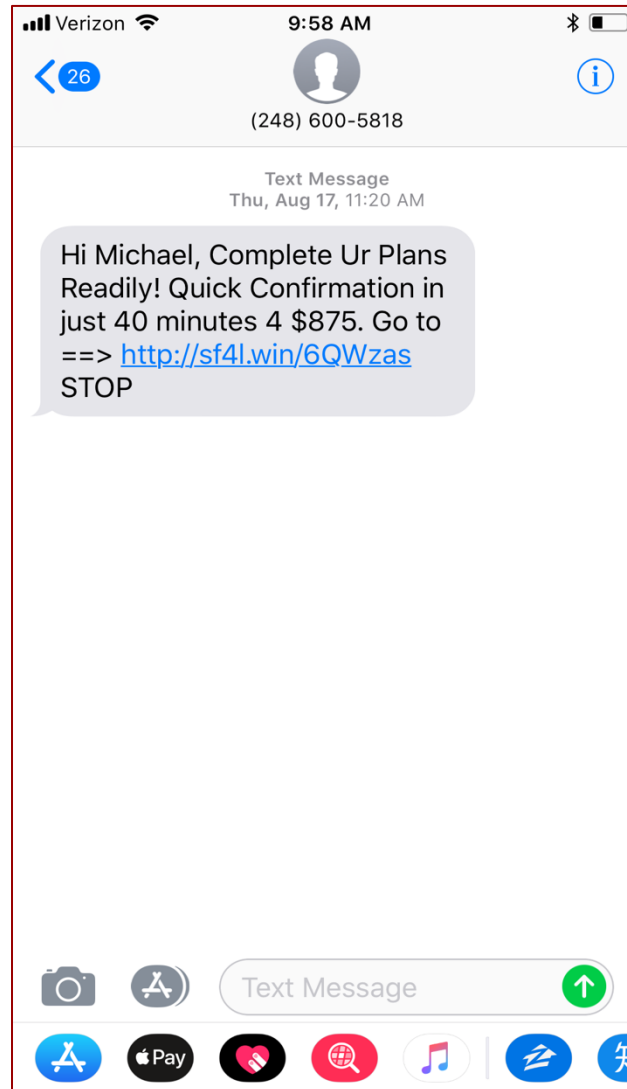
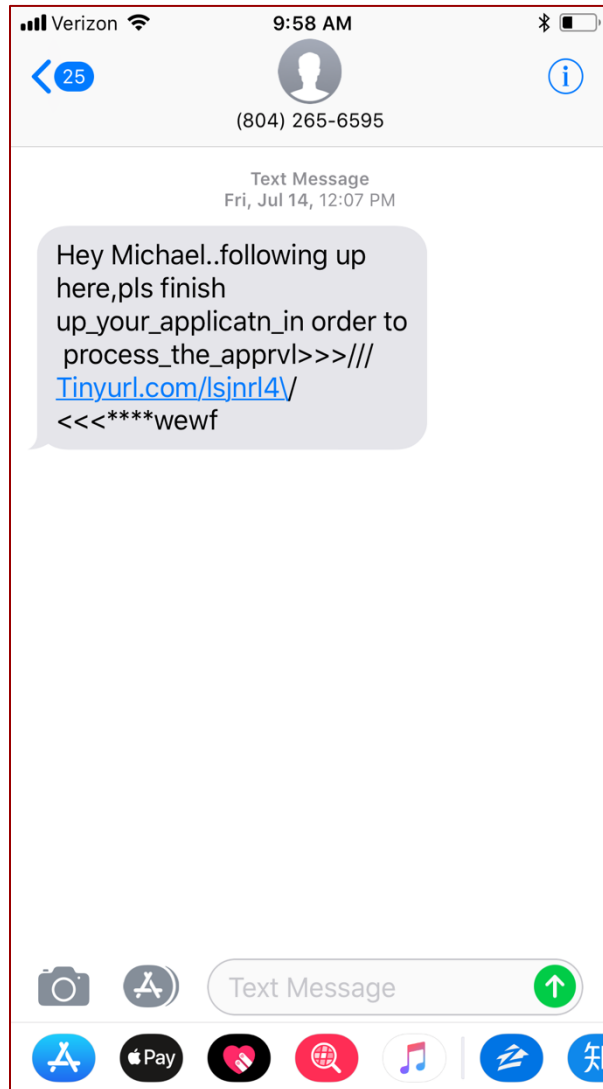


Text Message
Today 11:31

Please login to
verify & update
your Apple ID
[http://bit.ly/
221WKGW](http://bit.ly/221WKGW) You
will be unable to
use your Apple
ID or make
purchases until
this process is
completed



I also received these on my phone...



Facebook Phishing & Scams

- Messages or posts from hacked accounts such as friends or family
- Posts using tempting links for users to click on:
 - Free gift cards or discounted items
 - Donations for charity
 - Enticing videos or photos sometimes of yourself



Facebook Phishing & Scams



2015 Chevrolet Camaro

Yesterday at 11:40am · 🌐

For the second time in facebook history we are giving away two Chevrolet Camaros to two winners that we will select on August 10 completely at random.

Would you like to join this amazing giveaway for a chance to own a brand new Camaro ? Simply follow the steps below to enter the competition :

1. Share & Like this photo
2. Comment below your desired color

The winner will be messaged via inbox message

Good Luck



👍 Like 💬 Comment ➦ Share

977 people like this.

Top Comments ▾

1,627 shares



Charity For Nepal

April 26 at 12:45pm · Edited · 🌐

DONATE SOME MONEY..

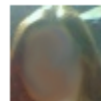
contact with me through facebook,i will go there and will collect it.

if u really a human being,don't upload status for showing only sympathy!!

do something unitedly!!

they will not get relief by your liking on this page only!

Like · Comment · Share



ha ha check this out..she is soo busted



CLICK HERE to see the status update that got a girl expelled from school!!

you got to see this

she's in such trouble

⚙ January 18 at 4:50pm via ef3 · Like · Comment

Vishing

- “Voice Phishing”
- Unsolicited phone calls
- Request for payment or personal information
- Sense of urgency such as fraud alert or virus



Vishing – why it works

- Can't be blocked by filters
- Victim has less time to make a decision unlike email
- Phishers can talk with the victim and be convincing
- Phone calls maybe include topics like:
 - Computer troubles
 - Donations or late bills
 - Family members in trouble



Nick's Vishing Example

- Caller invested an hour attempting to convince Nick to let him into his computer
- Caller used event viewer to “confirm” an infection on his computer
- Transferred to a “specialist” and given instructions to install remote control software
 - Teamviewer
 - Gotomypc

Level	Date and Time	Source	Event ID	Task Category
Error	7/5/2016 8:08:05 AM	WMI	10	None
Error	5/26/2016 8:19:17 AM	WMI	10	None
Error	6/1/2016 12:33:45 PM	WMI	10	None
Error	2/18/2016 8:27:15 AM	MsiInstaller	1024	None
Error	6/17/2016 8:14:31 AM	WMI	10	None
Error	6/13/2016 8:06:00 AM	WMI	10	None
Error	5/5/2016 1:39:18 PM	WMI	10	None
Error	4/5/2016 9:02:37 AM	WMI	10	None
Error	5/3/2016 4:51:30 PM	WMI	10	None
Error	4/26/2016 9:08:10 AM	WMI	10	None
Error	5/9/2016 12:56:46 PM	WMI	10	None



Example of Vishing

March 2024: Phone Refund Scam

Cyberattack on [REDACTED] has scammers targeting Nebraska patients

SCAMMERS TARGETING PATIENTS AFTER CYBERATTACK NEBRASKA HOSPITAL ASSOCIATION



- Scammers asking patients for credit card numbers
- Claim patients can get a full refund
- NHA: if you're suspicious of a call, hang up



A recent cyberattack c

has resulted in scammers targeting Nebraska patients.

Image source: 10/11 NOW local news

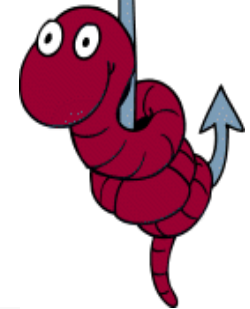
My Vishing example: NYSEG



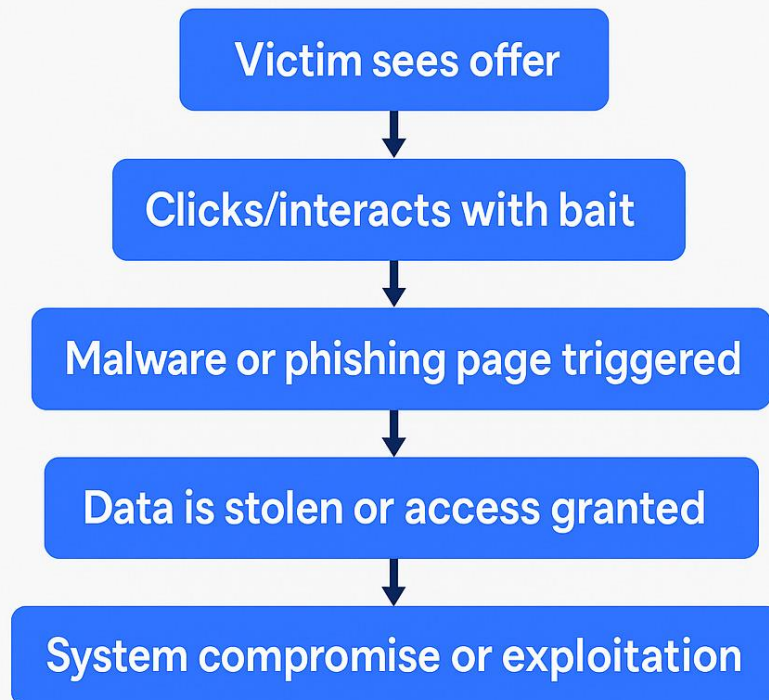
Almost duped into paying about \$150 😞

(3) Baiting

- Real world Trojan horse



Baiting Attack Flow



Key Targets of Baiting Attacks



Individuals

Why Targeted:

Take advantage of curiosity for free items.

Outcome:

Steal personal info, install malware.



Businesses

Why Targeted:

Access to sensitive corporate data.

Outcome:

Compromise systems, sell or exploit data.



Organizations

Why Targeted:

Access valuable data in government agencies and institutions.

Outcome:

Gain access to networks, steal or sell data.

Key Types of Baiting Attack Techniques





Example of Baiting

Early 2020: Operation Dream Job
(North Korean Cyber Espionage)

What do you have to offer?

14:30

We can give you your dream job you want

14:30

How is your job better?

14:30

Perhaps your salary will be more

14:31

What job are you offering?

14:31

Legal Operations Manager in MUT Aero Engines.
(JOB DESCRIPTION IN GERMAN)

14:31

I will translate to English for you...
What is your Email address

14:32

(Email address)

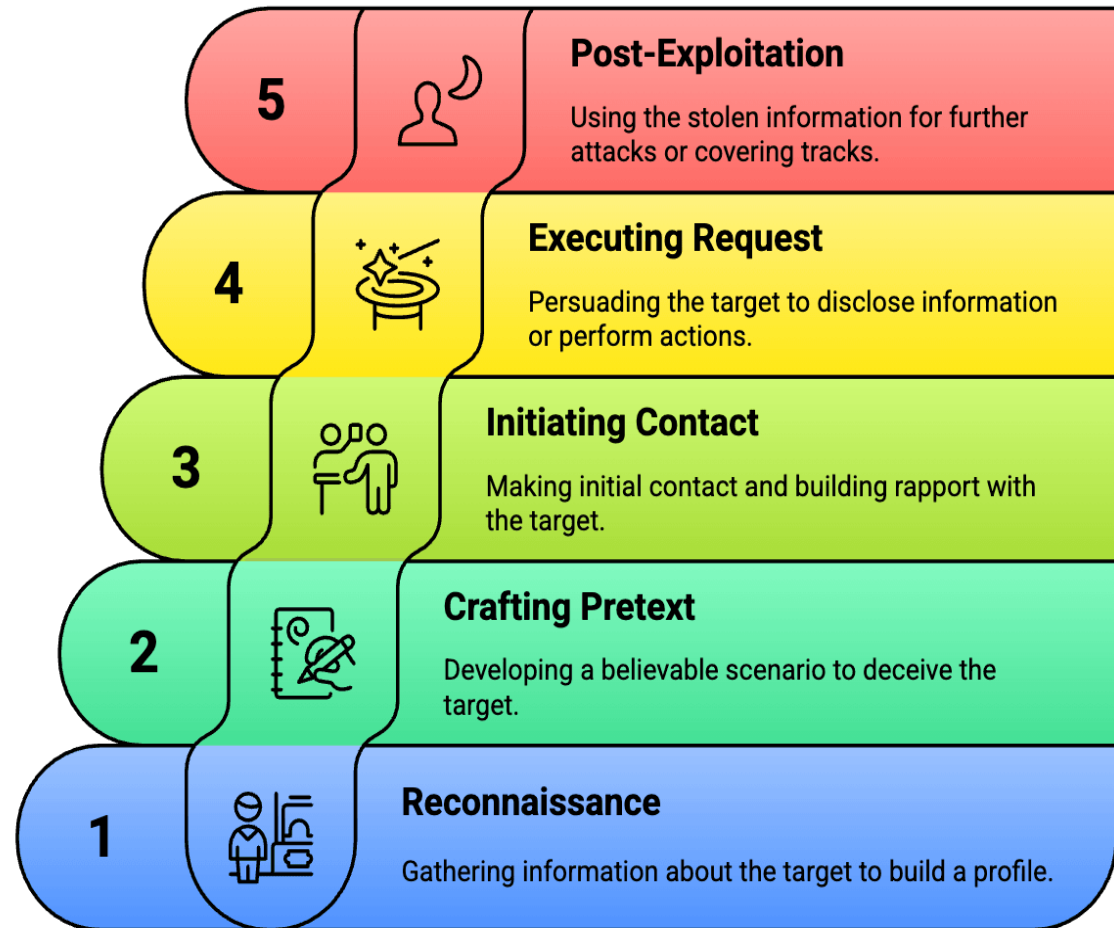
14:34

Image source: ClearSky Cyber Security

(4) Pretexting

- Invented Scenario

Pretexting Attack Workflow



The Most Common Pretexting Attacks

■ Grandparent scams:

- In this type of scam, a bad actor **impersonates the victim's grandchild or other close relative** and attempts to convince them that they're in a crisis.
- For example, they may claim they're in jail and need bail money.
- The threat actor can spoof the caller ID and make the incoming call appear as though it's coming from someone they know.
- If the victim falls for the scam, the threat actor will give them instructions for sending the money.



The Most Common Pretexting Attacks

■ Romance scams

- Romance scams are when threat actors pretend to **be an online love interest** in order to win over their victim's trust.
- This type of pretexting scam can take weeks, months or even years. Throughout the course of the scam, the threat actor will slowly start asking for things such as loans for an emergency or expensive gifts.
- In 2022, the FBI's Internet Crime Complaint Center (IC3) received more than 19,000 complaints about romance scams, with reported losses of almost [\\$740 million](#).



The Most Common Pretexting Attacks

■ CEO fraud

- CEO fraud is when a cybercriminal impersonates **their target's CEO** in an attempt to have them send money, often in the form of a gift card, or share sensitive information.
- To carry out this attack, the threat actor leverages phishing techniques to make the matter sound urgent.
- In some cases of CEO fraud, the bad actor will message or email the victim multiple times before making their request. This helps them build credibility and gain the victim's trust.



Pretexting Real Example:



- **Victim signed up for Free Credit Report**
- **Saw unauthorized charge** from another credit company
 - Called to **dispute charge** and was **asked for Credit Card Number**
 - They **insisted it was useless** without the security code
 - Asked for **Social Security number**

(5) Diversion Theft: **A Con**



- Persuade delivery person that **delivery is requested elsewhere** - *"Round the Corner"*
- When deliver is redirected, attacker persuades delivery driver to **unload delivery near address**
- **Ex:** Attacker parks **security van outside a bank**. **Victims going to deposit money** into a night safe are told that the **night safe is out of order**. **Victims then give money to attacker** to put in the fake security van
- Most companies do not prepare employees for this type of attack

An abstract graphic on the left side of the slide, featuring a dark blue background with glowing light blue lines and dots that form a complex, interconnected circuit or network pattern, reminiscent of a microchip or data flow.

Role of Artificial Intelligence (AI)



Vishing Skyrockets Post-ChatGPT

- Since the launch of ChatGPT in November 2022, vishing, smishing, and phishing attacks have increased by a staggering 1,265%.
- Research from [Enea](#) reveals that 76% of enterprises lack sufficient voice and messaging fraud protection, as AI-powered vishing and smishing skyrocket following the launch of ChatGPT.
- Advancements in technology and AI are lowering the barrier to entry for cybercriminals and increasing the sophistication of attacks.
- Generative AI tools like ChatGPT are predicted to play a role in crafting more effective cyberattacks in 2024, especially in the area of social engineering.



Image source: Reuters



AI Deepfake Video Call Scams

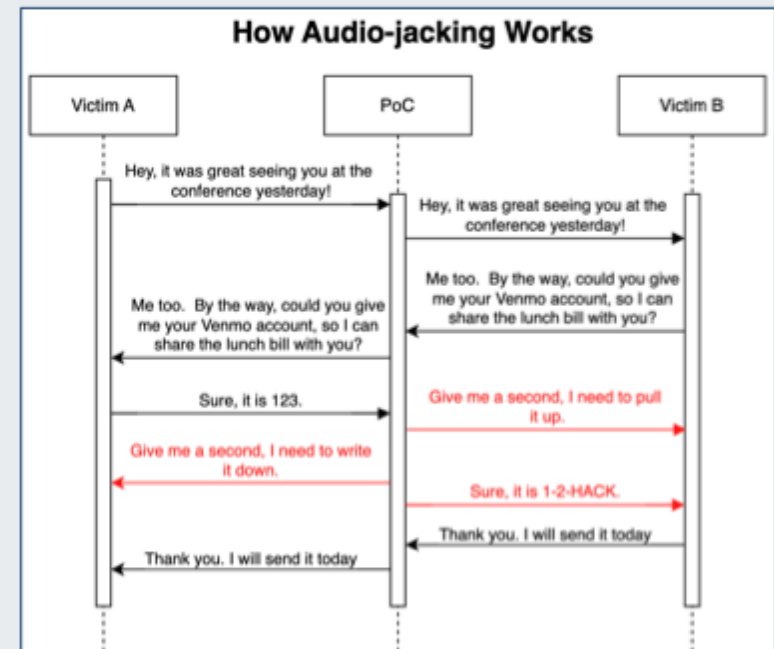
- In early 2024, scammers used artificial intelligence-powered “deepfakes” to pose as a multinational company’s chief financial officer in a video call and were able to trick an employee into sending them more than \$25 million, [CNN reported](#).
- The scam began with a phishing email that was initially deemed somewhat suspicious, but the deepfake video call bolstered the threat actors’ credibility and convinced the finance employee to transfer money to an offshore account.
- Likely sophisticated organized criminal organizations consisting of multiple individuals, supporting various roles throughout the duration of the scam.





Malicious LLMs for Social Engineering

- February 2024 saw [research](#) published by IBM on using generative AI to distort live audio transactions.
- Successful attempts to intercept and “hijack” a live conversation, using Live Language Models (LLM) to understand the conversation and manipulate the audio output unbeknownst to the speakers for a malicious purpose.
- The attack would require malware installed on the victims’ phones, or a malicious or compromised Voice over IP (VoIP) service.
- Presents the possibility of modifying medical information in phone conversations.



Source: IBM X-Force



Malicious LLMs for Social Engineering, cont.

- **WormGPT:** Launched in 2021 and has been used extensively in business email compromise (BEC) attacks; writes convincing phishing emails.
- **FraudGPT:** Active since July 2023, and can create phishing pages, phishing emails, and phishing SMSs, among other capabilities.
- **WolfGPT:** Active since July 2023 and primarily focuses on supporting code and exploit development but may also be used for advanced phishing attacks.



Weakest Link?

- No matter how strong your:
 - Firewalls
 - Intrusion Detection Systems
 - Cryptography
 - Anti-virus software
- **You** are the **weakest link** in computer security!
 - People are more vulnerable than computers
- *"The weakest link in the security chain is the human element"*
 - Kevin Mitnick



Human is the weakest link in cyber security

- “What is fascinating—and disheartening—is that over 95 percent of all incidents investigated recognize ‘**human error**’ as a contributing factor.”

– IBM Security Services 2014
Cyber Security Intelligence Index



Final story: “I deserve an F in security”

I deserve an F in security

Inbox x



[REDACTED]@binghamton.edu>

11/21/15



to me ▾

Hey Professor,

Two days ago I was a victim of fraud and identity. Someone called me claiming they were from Chase fraud prevention. I didn't believe them at first, but they assured me if I called Chase and conference them in then they could verify themselves. So I did and they were able to verify themselves with the Chase representative. (The fraud stole a valid Chase employee information)

So upon his verification, I answered all his questions. I was tired so I just wanted to end the call and sleep so I gave him everything! My SSN, DoB, address -- everything!! I called Chase after and they said they don't have this on file and I was never called by that person on their system. He was a fake.

Soon after he tried transferring \$1800 from my bank account to a gmail account via QuikPay from Chase. I basically skipped work yesterday to sort this mess out with all my banks. I couldn't file a police report though because they said I lost nothing physical. I put security freezes on my credit, also.

Not sure what to do now. I deserve an F in security. I thought after I took your class I would never fall to these phishing attacks, but I did. Total failure.

Summary of Offense-Based Cybersecurity

Lecture 1: Introduction

- **What is security, information security, cybersecurity?**
- **Primary information security goals: CIA**
- **Secondary information security goals: AAA**
- **Challenges for science of cybersecurity**

Lecture 2: Terminology and taxonomy

- **Attack surface and vector**
- **Security risk analysis**
- **Security models**

Lecture 3: Scanning and reconnaissance

- **Public/online reconnaissance tools**
- **Port scanners**
- **Network mappers**
- **Operation system detection tools**
- **Firewall analysis tools**
- **Vulnerability scanners**
- **Packet sniffers**
- **Wireless sniffers**

Lecture 4: Exploitation of network vulnerabilities

- Cache poisoning attacks
- Sniffing
- Denial of service attacks

Lecture 5: Exploitation of memory vulnerabilities

- Stack-based attacks

- *Heap-based attacks*

Lecture 6: Exploitation of web vulnerabilities

- Primer on web applications
- Same-origin policy
- XSS: cross-site scripting
- SQL injection
- XSRF: cross-site request forgery

Lecture 7: Exploitation of system vulnerabilities

- OS protection principles
- *Privilege escalation: exploitation of a kernel bug*
- *Privilege escalation: race condition*

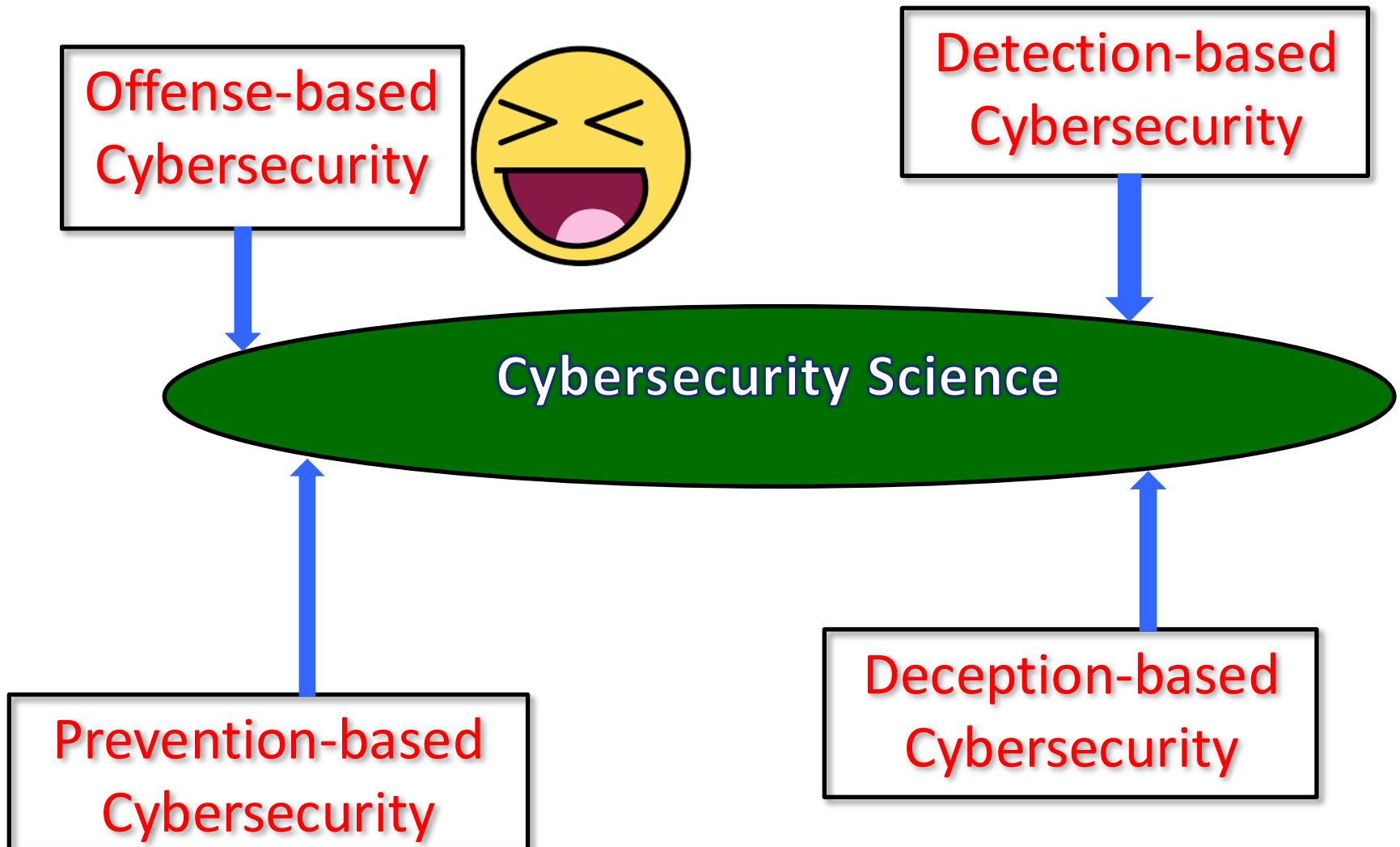
Lecture 8: Exploitation of hardware vulnerabilities

- Basics of computer architecture
- Side channel attacks based on caches
- Meltdown: out-of-order execution
- Spectre: speculative branch

Lecture 9: Exploitation of human vulnerabilities

- **What is Social Engineering Attack?**
- **Types of Social Engineering Tactics**
- **Role of AI in Social Engineering Attacks**

Overview of cybersecurity science



Reminder: First Quiz

- 1:45-2:30 PM Sept. 22
- Location: In classroom
- 25 True/False questions
- Closed-book



End of Lecture 9